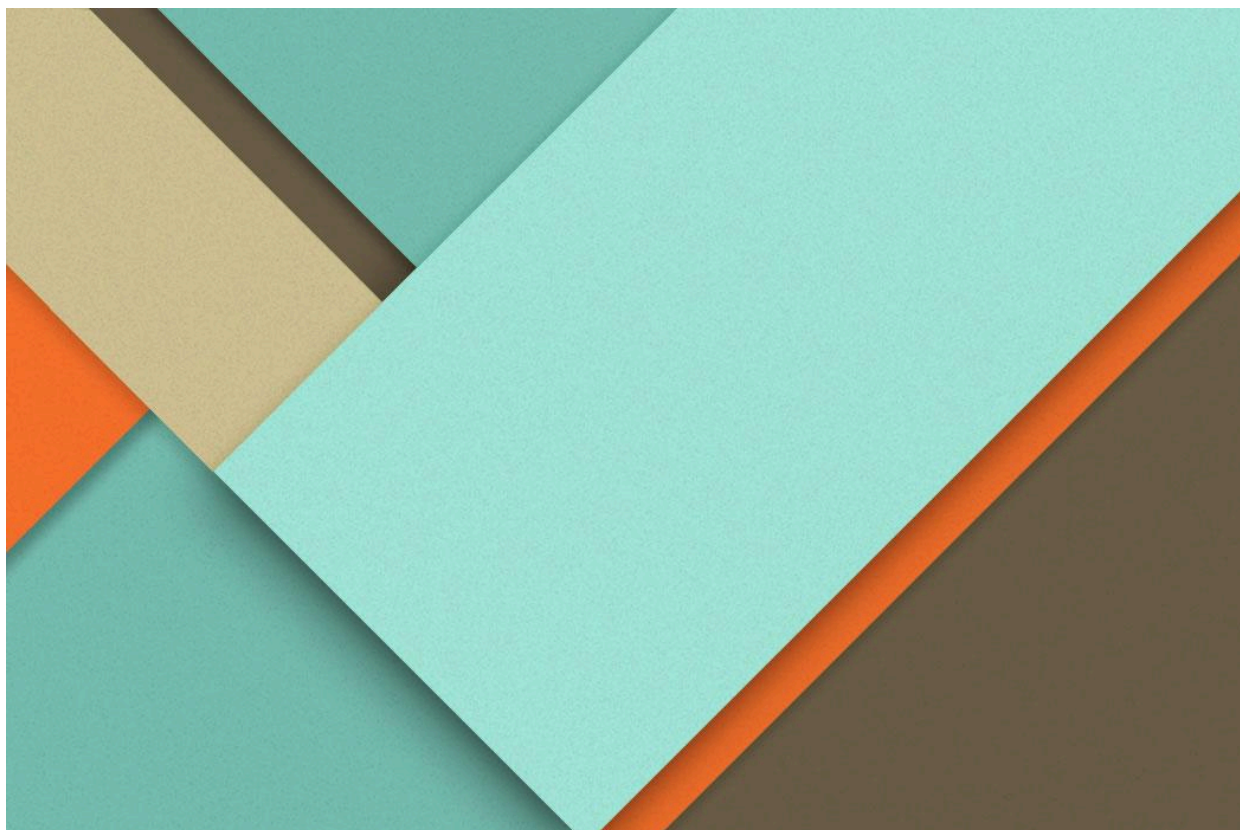




Plan de Recuperación ante Desastre

31.01.2025

1. Introducción

Este informe detalla el plan de respuesta a incidentes desarrollado para abordar y mitigar los efectos de incidentes de seguridad, específicamente en el contexto de un servidor Debian comprometido. Se basa en las mejores prácticas de la industria, incluyendo el NIST SP 800-61 y la norma ISO 27001.

2. Plan de respuesta a Incidentes

El plan de respuesta a incidentes se estructura en las siguientes fases:

❖ **Identificación:**

- Detección temprana de actividad inusual en el servidor Debian (registros de eventos, alertas de seguridad, etc.).
- Análisis forense para determinar el alcance y la naturaleza del incidente.
- Documentación detallada de los hallazgos.

❖ **Contención:**

- Aislamiento del servidor comprometido para evitar la propagación del incidente.
- Desconexión de la red, si es necesario.
- Restricción de cuentas de usuario comprometidas.

❖ **Erradicación:**

- Eliminación del malware o software malicioso.
- Restauración del sistema desde copias de seguridad limpias.
- Parcheo de vulnerabilidades explotadas.

❖ **Recuperación:**

- Restablecimiento de los servicios afectados.
- Monitoreo continuo para asegurar la estabilidad del sistema.
- Evaluación post-incidente para identificar lecciones aprendidas.

3. Respuesta a situaciones similares

En caso de un ataque similar, la organización respondería de la siguiente manera:

- ❖ **Activación del Plan de Respuesta a Incidentes:** El equipo de respuesta a incidentes se movilizará para ejecutar el plan.
- ❖ **Análisis Forense:** Se llevaría a cabo un análisis exhaustivo para comprender el vector de ataque, el alcance de la intrusión y los datos comprometidos.

- ❖ **Contención y Erradicación:** Se tomarían medidas para aislar el servidor afectado, eliminar cualquier software malicioso y restaurar el sistema desde copias de seguridad.
- ❖ **Recuperación y Restauración:** Se restablecerían los servicios afectados y se implementarían medidas de seguridad adicionales para prevenir futuras intrusiones.

4. Prevención de recurrencia

Para prevenir la recurrencia de incidentes similares, se implementará una serie de medidas de seguridad. En primer lugar, se fortalecerá la seguridad del servidor mediante la configuración segura del sistema operativo Debian, la implementación de firewalls y sistemas de detección de intrusiones, la actualización regular del software y parches de seguridad, y el endurecimiento de contraseñas con autenticación de dos factores.

En segundo lugar, se implementará un sistema de monitoreo y alerta para detectar actividades sospechosas y notificar al equipo de seguridad sobre eventos críticos. Esto incluye herramientas de monitoreo de seguridad y la configuración de alertas.

En tercer lugar, se proporcionará capacitación y concienciación al personal en seguridad informática y buenas prácticas, incluyendo los riesgos de phishing, malware y otras amenazas. Se realizarán análisis de vulnerabilidades y pruebas de penetración periódicas. Además, se revisará y actualizará continuamente el plan de respuesta a incidentes para garantizar su eficacia y relevancia ante nuevas amenazas.

5. Protección de datos

La protección de los datos es una prioridad, por lo que se implementarán los siguientes mecanismos:

Respaldos periódicos

Se realizan copias de seguridad de los datos críticos de forma regular. Estas copias se almacenarán en un lugar seguro, ya sea físico (como una caja fuerte o un disco duro externo) o en la nube (utilizando un proveedor de servicios confiable). Los respaldos periódicos garantizan que, en caso de pérdida o daño de los datos originales, se puedan recuperar de forma rápida y eficiente.

Cifrado de datos sensibles

Los datos confidenciales se cifran tanto en tránsito (cuando se envían a través de la red) como en reposo (cuando se almacenan en dispositivos). El cifrado protege los datos de accesos no autorizados, incluso si un atacante logró interceptarlos o acceder al sistema de almacenamiento. Se utilizarán algoritmos de cifrado robustos y claves de cifrado seguras.

Controles de acceso estrictos

Se implementarán controles de acceso basados en roles para limitar el acceso a los datos según la necesidad. Esto significa que cada usuario tendrá acceso solo a la información que necesita para realizar sus tareas. Los controles de acceso se basarán en el principio de "mínimo privilegio", lo que significa que a los usuarios se les otorgará el nivel de acceso más bajo posible que aún les permita realizar su trabajo.

6. Sistema de Gestión de Seguridad de la información (SGSI)

Se desarrollaría un SGSI conforme a la norma 27001, que incluiría:

Análisis de riesgos

Descripción del proceso de evaluación de riesgos, incluyendo la metodología utilizada, la identificación de activos, amenazas y vulnerabilidades, y la determinación del impacto y la probabilidad de ocurrencia de los riesgos.

Se adoptará una metodología híbrida cualitativa/cuantitativa. Esta metodología combina el juicio experto (cualitativo) con elementos cuantitativos donde es factible, permitiendo una evaluación más completa y fundamentada. El proceso se divide en las siguientes etapas:

- ❖ **Identificación de Activos:** Se elaboró un inventario exhaustivo de todos los activos relevantes del sistema Oyster, clasificándolos en categorías: Hardware, Software, Datos, Personal y Servicios.
- ❖ **Identificación de Amenazas:** Se identificaron las posibles amenazas, tanto internas como externas, que podrían afectar a los activos.
- ❖ **Identificación de Vulnerabilidades:** Se identificaron las debilidades en los activos que podrían ser explotadas por las amenazas.
- ❖ **Análisis de Riesgos:** Se analizó la probabilidad de ocurrencia de cada amenaza y el impacto potencial en la organización en caso de materializarse.
- ❖ **Evaluación de Riesgos:** Se determinó el nivel de riesgo para cada combinación de amenaza-vulnerabilidad, utilizando una matriz de riesgos.

Políticas de Seguridad

Esta Política de Seguridad de la Información establece los principios y objetivos generales que guían la gestión de la seguridad de la información y se aplica a todos los empleados, contratistas, proveedores y terceros que acceden, utilizan o gestionan información.

La política se basa en los siguientes principios fundamentales:

- ❖ **Confidencialidad:** Asegurar que la información sea accesible solo a personas autorizadas y protegerla contra accesos no autorizados, divulgación o exposición.
- ❖ **Integridad:** Mantener la exactitud, completitud y consistencia de la información, protegiéndola contra modificaciones no autorizadas o corrupción.
- ❖ **Disponibilidad:** Garantizar que la información esté accesible para las personas autorizadas cuando la necesiten para llevar a cabo sus funciones y responsabilidades.
- ❖ **Legalidad y Cumplimiento:** Cumplir con todas las leyes, regulaciones y obligaciones contractuales aplicables en materia de protección de datos y seguridad de la información, incluyendo el Reglamento General de Protección de Datos (RGPD) y la legislación del Reino Unido.
- ❖ **Gestión de Riesgos:** Implementar un enfoque basado en la gestión de riesgos para identificar, evaluar, tratar y monitorear los riesgos de seguridad de la información, priorizando la protección de los activos de información críticos.
- ❖ **Concienciación y Formación:** Promover una cultura de seguridad de la información en toda la organización, proporcionando formación y concienciación continua al personal sobre sus responsabilidades en materia de seguridad.
- ❖ **Mejora Continua:** Comprometerse con la mejora continua del SGSI, revisando y actualizando periódicamente las políticas, los procedimientos y los controles de seguridad para adaptarlos a las nuevas amenazas y a los cambios en el entorno.

Mejora Continua

La organización se compromete a proteger la confidencialidad, integridad y disponibilidad de la información y activos asociados. Este compromiso incluye cumplir con todas las leyes y regulaciones aplicables, así como implementar controles y procedimientos necesarios para mitigar los riesgos de seguridad identificados. La seguridad de la información es una prioridad estratégica y será gestionada mediante la



implementación y mantenimiento de un Sistema de Gestión de Seguridad de la Información (SGSI) basado en estándares internacionales como ISO/IEC 27001.